Healthcare IAM Risk Assessment (R01-R05)

Risk assessment — 2.0

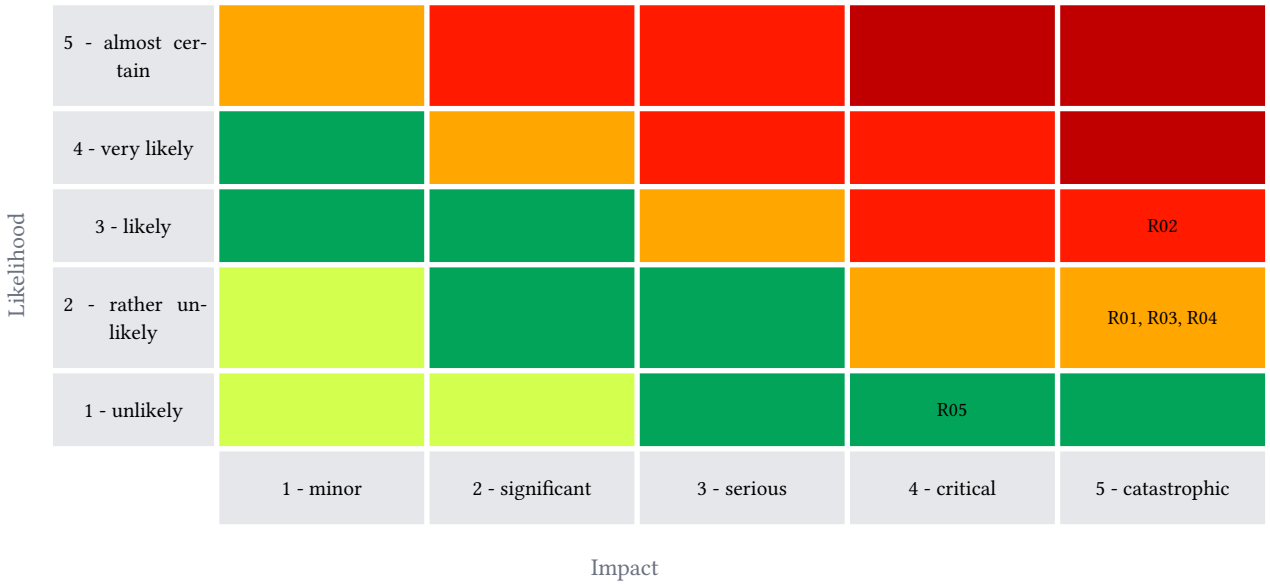
IAM risk register for Care Access Navigator (HRMC, synthetic data): R01-R05 from the Risk Management 1 register, scored on the 5x5 ISO 27005 matrix (inherent, current, residual), linked to assets, applied controls and exceptions. v1.0 (2026-11-03) covered R02 only; its exports are kept in the repository. Educational simulation; not a certification.

Domain	Care Access Navigator - IAM & GRC
Perimeter	Care Access Navigator - IAM & GRC/Mock EHR - Workforce Access Governance
Risk matrix	5x5 ISO-27005
Status	In progress
Authors	akchrao@gmail.com
Reviewers	-
ETA / Due	- — -

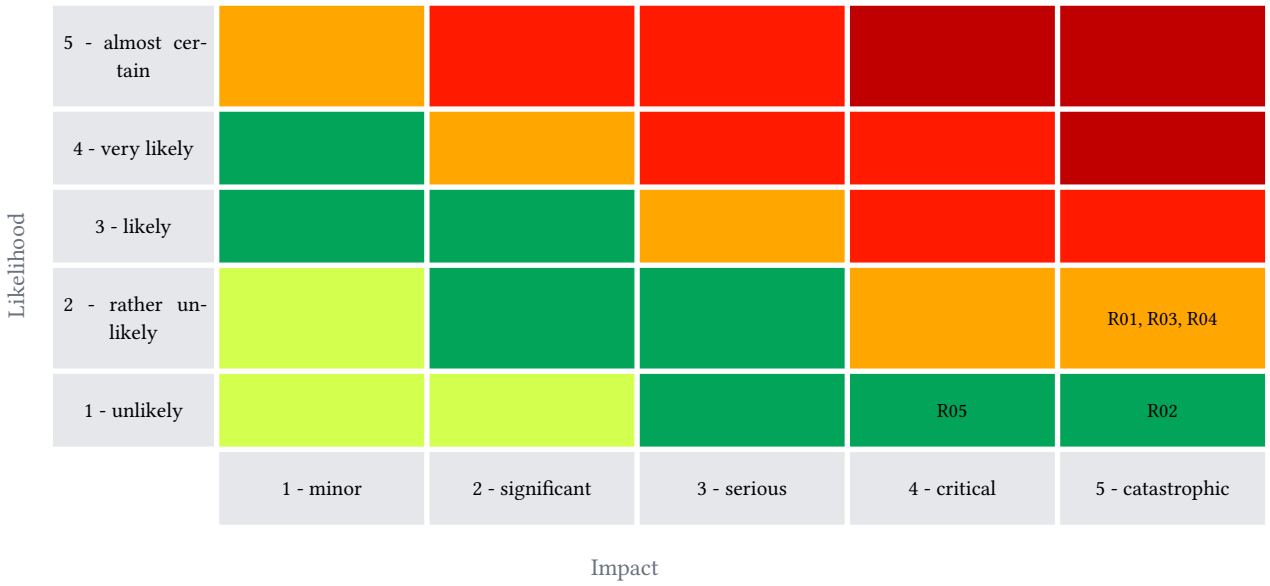
Generated at 2026-11-09 17:33:13 UTC
Document ID `dcf0b5f0-1ca0-448c-b8bd-a05b4f7b7dbc`

Risk matrix

Current risk



Residual risk



Scenario summary

Ref.	Name	Description	Current	Residual	Treatment
R01	Excessive RBAC privileges	Excessive RBAC privileges. Treatment: Least privilege + quarterly access review.	3 - medium	3 - medium	Mitigate
R02	Incomplete Leaver Deprovisioning Across Entra ID and Keycloak	A terminated healthcare employee may retain access to the Mock EHR application because disabling their Microsoft Entra ID account does not automatically disable the corresponding federated Keycloak account. During Jeevan Smith's termination (TERM-2026-0301), Entra ID access was disabled, but the Keycloak account required additional manual deactivation. This creates a potential risk of unauthorized access through stale accounts or existing sessions. The risk will be evaluated using the project's existing R02 risk assessment, JML evidence, and HIPAA-aligned workforce termination controls.	4 - high	2 - low	Mitigate
R03	Credential compromise	Credential compromise. Treatment: MFA + lockout + failed-login monitoring.	3 - medium	3 - medium	Mitigate
R04	Privileged account misuse	Privileged account misuse. Treatment: Restricted admin roles + monitoring.	3 - medium	3 - medium	Mitigate
R05	Expired vendor access	Expired vendor access. Treatment: Expiration date + periodic review.	2 - low	2 - low	Mitigate

Risk scenarios

5 scenarios.

R01 — Excessive RBAC privileges

Description	Excessive RBAC privileges. Treatment: Least privilege + quarterly access review.
Assets	Keycloak Identity Provider (realm care-access-navigator), HR Application, Mock EHR Application, Microsoft Entra ID (workforce identity source), Billing Application, Patient Portal
Existing controls	Access is reviewed periodically and findings are remediated, Role changes remove old access before new access is granted, Each application admits only approved job roles, Control gaps are tracked to verified remediation, Users receive only the access their job requires (RBAC, least privilege), Security risks are identified, scored and treated
Current level	3 - medium
Residual level	3 - medium
Strength of knowledge	--
Treatment	Mitigate
Justification	Owner: IAM Analyst. Source: RiskMgmt1 C2-C4. Frameworks: NIST CSF PR.AA; ISO 27001 A.5.15/5.18. Treatment status (register 2026-11-03): Implemented - Group RBAC + app gates + quarterly review (TC-01, TC-02, TC-07). Register residual score 10 (High) entered as likelihood 2 x impact 5.

R02 — Incomplete Leaver Deprovisioning Across Entra ID and Keycloak

Description	A terminated healthcare employee may retain access to the Mock EHR application because disabling their Microsoft Entra ID account does not automatically disable the corresponding federated Keycloak account. During Jeevan Smith's termination (TERM-2026-0301), Entra ID access was disabled, but the Keycloak account required additional manual deactivation. This creates a potential risk of unauthorized access through stale accounts or existing sessions. The risk will be evaluated using the project's existing R02 risk assessment, JML evidence, and HIPAA-aligned workforce termination controls.
Assets	Keycloak Identity Provider (realm care-access-navigator), Mock EHR Application, Microsoft Entra ID (workforce identity source)
Existing controls	Access is reviewed periodically and findings are remediated, Terminated users are disabled and all access removed promptly, Control gaps are tracked to verified remediation, Security risks are identified, scored and treated, Workforce Termination and Access Revocation
Current level	4 - high
Extra controls	Automated Keycloak Leaver Deprovisioning
Residual level	2 - low
Strength of knowledge	--
Treatment	Mitigate
Justification	Owner: IAM Analyst + HR/Workforce. Source: RiskMgmt1 C2-C4. Frameworks: NIST CSF PR.AA; ISO 27001 A.5.18. Treatment status (register 2026-11-03): Implemented - Leaver automation verified (TC-04); leftover role fixed (CA-09). Register residual score 5 (Moderate) entered as likelihood 1 x impact 5. CISO current level stays 3x5 because CAN-CTRL-JML-002 test 1 (automatic Entra-to-Keycloak disable) is not done; the register residual is the target.

R03 — Credential compromise

Description	Credential compromise. Treatment: MFA + lockout + failed-login monitoring.
Assets	Keycloak Identity Provider (realm care-access-navigator), Microsoft Entra ID (workforce identity source)
Existing controls	Alerts are raised and investigated, Incidents are handled with a tested playbook, Security-relevant identity events are logged, Control gaps are tracked to verified remediation, Security risks are identified, scored and treated, Lockout after repeated failures; strong password standard
Current level	3 - medium
Extra controls	Security logs are kept 12 months, ePHI and credentials are encrypted in transit (TLS 1.2+), Privileged and cardholder-data users pass MFA
Residual level	3 - medium
Strength of knowledge	--
Treatment	Mitigate
Justification	Owner: IAM Analyst + Security Analyst. Source: RiskMgmt1 C2-C4. Frameworks: NIST CSF PR.AA/DE.CM; ISO 27001 A.8.5. Treatment status (register 2026-11-03): Partially implemented -

	MFA + lockout enforced (EV-13); Entra MFA and 12-month logs open (EX-01, EX-02). Register residual score 10 (High) entered as likelihood 2 x impact 5.

R04 — Privileged account misuse

Description	Privileged account misuse. Treatment: Restricted admin roles + monitoring.
Assets	Keycloak Identity Provider (realm care-access-navigator), Microsoft Entra ID (workforce identity source)
Existing controls	Alerts are raised and investigated, Incidents are handled with a tested playbook, Security-relevant identity events are logged, Control gaps are tracked to verified remediation, Security risks are identified, scored and treated
Current level	3 - medium
Extra controls	Privileged access is approved, limited and monitored
Residual level	3 - medium
Strength of knowledge	--
Treatment	Mitigate
Justification	Owner: IAM Analyst + Security Analyst. Source: RiskMgmt1 C2-C4. Frameworks: NIST CSF PR.AA/DE.CM; ISO 27001 A.8.2. Treatment status (register 2026-11-03): Partially implemented - Privileged groups need MFA; CAN-ID-005 alerts; admin MFA exception (EX-03). Register residual score 10 (High) entered as likelihood 2 x impact 5.

R05 — Expired vendor access

Description	Expired vendor access. Treatment: Expiration date + periodic review.
Assets	Keycloak Identity Provider (realm care-access-navigator)
Existing controls	Control gaps are tracked to verified remediation, Security risks are identified, scored and treated
Current level	2 - low
Extra controls	Vendor access is sponsored, time-boxed and removed at expiry
Residual level	2 - low
Strength of knowledge	--
Treatment	Mitigate
Justification	Owner: IAM Analyst (vendor expiry detection: Security Analyst). Source: RiskMgmt1 C2-C4. Frameworks: NIST CSF GV.SC/PR.AA; ISO 27001 A.5.19/5.20. Treatment status (register 2026-11-03): Partially implemented - Vendor end date enforced for new vendors (TC-08); test.vendor1 open (CA-08). Register residual score 4 (Low) entered as likelihood 1 x impact 4.